COMPLIANCE PRIMER · AZURE + DATABRICKS

Compliance in Azure Databricks: the compliance security profile and a platform security baseline

A **security baseline** is the set of controls every workspace must have. The **compliance security profile** hardens the compute that runs your code in workspaces that process regulated data.

> LEARNING OBJECTIVE
>
> Describe the compliance security profile and how to establish a platform security baseline.

01 Why: what goes wrong without a baseline

Why a compliance baseline?

Every workspace starts with sensible defaults, but regulated data needs more, and it needs the same controls everywhere. Without a baseline, each team configures its own workspace and the weakest one sets your real security level.

RISK	PROTECTION
Each team configures its own workspace; one leaves public access open	**One baseline.** The same controls on every workspace, deployed from code.
Settings are changed by hand and silently drift	**Drift checks.** Scheduled scans compare each workspace to the baseline.
Unpatched cluster images run for months	**Compliance security profile.** Hardened images and automatic monthly updates.
An auditor asks you to prove regulated data is protected	**Documented controls.** A baseline gives you a list to evidence, control by control.

THE CYCLE **Define** the baseline → **Enforce** it on every workspace → **Log** every action → **Review** and alert

02 The compliance security profile

The compliance security profile (CSP) is a workspace setting for processing regulated data such as health records (HIPAA) or card data (PCI-DSS). It changes the **compute plane**: cluster VMs run a hardened image with security monitoring agents and are patched on a fixed schedule. It requires the Premium plan and the Enhanced Security and Compliance add-on.

CAPABILITY	STANDARD WORKSPACE	WITH COMPLIANCE SECURITY PROFILE
Compute image	Standard Databricks Runtime image	+ CIS-hardened image with security agents installed
Malware and file integrity monitoring	Off, unless enhanced security monitoring is enabled on its own	+ On: antivirus, behaviour-based malware detection and file integrity monitoring
Vulnerability scanning	Not performed on cluster hosts	+ Hosts are scanned regularly for vulnerabilities
Patching	Clusters pick up fixes when you restart them	+ Automatic cluster update restarts compute in a monthly maintenance window
Monitoring events	None	+ Written to audit logs (e.g. service names capsule8-alerts-dataplane, clamAVScanService-dataplane)
Available features	All GA and preview features	! Only features and runtimes supported for the profile
Can be turned off	Not applicable	! No. Permanent for the workspace
Cost	Included in the plan	! Enhanced Security and Compliance add-on charge

WHERE TO TURN IT ON

> **Account console:** enable for all new workspaces in the account, so no workspace is created without it.

> **Workspace:** enable on an existing workspace in its security settings, or at creation in ARM, Bicep or Terraform.

> **Standards:** choose the ones you process (e.g. HIPAA, PCI-DSS). This records intent; the controls applied are the same.

BEFORE YOU ENABLE

It **cannot be turned off** for that workspace.

Running compute must be restarted to pick up the hardened image.

Monthly maintenance restarts long-running clusters and streaming jobs. Design them to recover.

Some preview features and older runtimes are unavailable. Check the supported list.

WHAT IT DOES NOT DO

> Make you compliant. You remain responsible for access control, network design, data handling and your own evidence.

> Replace the rest of the baseline. It hardens compute; identity, network and data controls are still yours to configure.

03 Establishing a platform security baseline

A baseline is a written list of controls applied to every workspace, deployed as code so it can't drift. Controls are configured in four places: **Entra ID**, **Azure**, the **Databricks account** and each **workspace**. Tick each control to assess a workspace.

Identity

0/4

- [ ] Single sign-on with Entra ID; Conditional Access requires MFA for Azure Databricks
  `ENTRA ID`
- [ ] Identities synced to the account; no local workspace users
  `DATABRICKS ACCOUNT`
- [ ] Few admins; PIM for Azure roles on the workspace
  `ENTRA ID`
- [ ] Personal access tokens disabled or limited to a short lifetime
  `WORKSPACE`

Network

0/4

- [ ] VNet injection with secure cluster connectivity (no public IPs)
  `AZURE`
- [ ] Private Link for front-end and back-end, or IP access lists
  `AZURE`
- [ ] Outbound traffic routed through a firewall
  `AZURE`
- [ ] Storage and Key Vault firewalls with private endpoints
  `AZURE`

Data

0/4

- [ ] Unity Catalog on every workspace; no business data in DBFS root
  `DATABRICKS ACCOUNT`
- [ ] Storage reached through the Access Connector managed identity; shared key access disabled
  `AZURE`
- [ ] Grants to groups; row filters and column masks on sensitive columns
  `UNITY CATALOG`
- [ ] Customer-managed keys where regulation requires key control
  `AZURE`

Compute

0/4

- [ ] Cluster policies for all users; unrestricted cluster creation removed
  `WORKSPACE`
- [ ] Only Unity Catalog access modes (standard or dedicated)
  `WORKSPACE`
- [ ] Auto-termination on all-purpose compute
  `WORKSPACE`
- [ ] Compliance security profile on workspaces with regulated data
  `DATABRICKS ACCOUNT`

Workspace settings

0/3

- [ ] Results download and notebook export off where not needed
  WORKSPACE
- [ ] Verbose audit logs on
  WORKSPACE
- [ ] Secrets in Key Vault-backed scopes only
  WORKSPACE

Monitoring

0/4

- [ ] Diagnostic settings deliver logs to Log Analytics or Sentinel
  AZURE
- [ ] Security team has SELECT on system.access
  UNITY CATALOG
- [ ] Alerts on admin changes, grants and failed sign-ins
  AZURE
- [ ] Security Analysis Tool runs on a schedule
  WORKSPACE

1 · DEFINE

Write the baseline as a short standard, with an owner and an exception process.

2 · DEPLOY AS CODE

Terraform or Bicep creates every workspace with the same settings. Azure Policy blocks non-compliant resources.

3 · CHECK FOR DRIFT

Run the Databricks Security Analysis Tool (SAT) on a schedule. It scores workspaces against best-practice checks.

Baseline first, profile where required

Every workspace gets the baseline. Add the compliance security profile to workspaces that process regulated data.

Deploy as code, check for drift

A control that was configured by hand once will not stay configured. Terraform, Azure Policy and SAT keep it in place.